

SOC Internship Day 31 – Active Directory Attack Detection

Objective

Learn how Security Operations Center (SOC) analysts detect and investigate advanced Active Directory (AD) attacks within enterprise environments.

1. What is Active Directory (AD)?

Active Directory is Microsoft's centralized identity and access management system used in enterprise networks. It manages users, computers, groups, authentication, and authorization across an organization.

Key Functions

- User authentication
- Access control
- Group policy management
- Centralized administration
- Resource management

2. Why Attackers Target Active Directory

Active Directory is often called the "keys to the kingdom" because compromising it can provide control over an entire enterprise network.

Reasons

- Centralized authentication system
- Access to sensitive resources
- Privilege escalation opportunities
- Potential domain-wide compromise

3. Kerberoasting Attack

Kerberoasting is an attack where adversaries request Kerberos Service Tickets (TGS) for service accounts and perform offline password cracking to recover credentials.

Attack Process

1. Attacker gains access to a domain account.
2. Requests service tickets for service accounts.
3. Extracts encrypted ticket data.
4. Cracks passwords offline.
5. Uses compromised credentials for lateral movement.

Indicators of Compromise (IOCs)

- Unusual Kerberos ticket requests
- High volume of TGS requests
- Targeting of multiple service accounts
- Authentication anomalies

Detection Methods

- Monitor Event ID 4769
- Identify abnormal TGS request volumes
- Alert on service account enumeration

4. Golden Ticket Attack

A Golden Ticket attack occurs when attackers obtain the KRBTGT account hash and create forged Ticket Granting Tickets (TGTs), allowing unrestricted access to domain resources.

Indicators

- Suspicious Kerberos authentications
- Abnormally long ticket lifetimes
- Unauthorized privileged access
- Authentication from unusual systems

Detection

- Monitor Kerberos logs
- Check ticket validity periods
- Investigate unusual administrative activity

5. DCSync Attack

DCSync is a technique where attackers impersonate a Domain Controller and request password hashes from Active Directory replication services.

Indicators

- Replication requests from non-domain controllers
- Unexpected directory replication activity
- Credential dumping attempts
- Access to sensitive account hashes

Detection

- Monitor replication permissions
- Alert on replication traffic from non-DC hosts
- Analyze credential access events

6. LDAP Abuse

Lightweight Directory Access Protocol (LDAP) is used to query AD information. Attackers abuse LDAP to gather information about users, groups, and privileges.

Indicators

- Excessive LDAP queries
- Enumeration of privileged accounts
- Large authentication requests
- Reconnaissance activity

Detection

- Analyze LDAP traffic patterns
- Monitor user enumeration attempts
- Alert on excessive directory searches

7. Domain Privilege Escalation

Attackers attempt to gain Domain Admin or higher privileges to control the environment.

Common Methods

- Token impersonation
- Misconfigured permissions
- Credential theft
- Pass-the-Hash attacks
- Exploitation of vulnerable services

Risks

- Full domain compromise
- Data theft
- Persistence mechanisms
- Lateral movement

8. Detection Techniques

SOC teams use multiple detection methods to identify AD attacks.

Monitoring Areas

- Kerberos authentication logs
- Directory replication activities
- Privileged group membership changes
- LDAP traffic analysis
- Suspicious authentication attempts

Tools Used

- SIEM Platforms
- Microsoft Defender
- Splunk
- Elastic Security
- Windows Event Logs

9. SOC Workflow for AD Attack Detection

The standard investigation process is:

AD Logs Collected

↓

SIEM Correlation

↓

Suspicious Activity Detected

↓

SOC Investigation

↓

Incident Response

Investigation Steps

1. Review alert details.
2. Validate suspicious behavior.
3. Analyze affected accounts.
4. Identify attack techniques.
5. Contain and remediate threats.
6. Document findings.

10. SOC Team Responsibilities

Different SOC tiers have specific responsibilities.

L1 Analyst

- Monitor AD alerts
- Initial triage
- Escalate suspicious events

L2 Analyst

- Investigate authentication anomalies

- Analyze attack patterns
- Confirm incidents

L3 Analyst

- Perform threat hunting
- Conduct advanced investigations
- Lead incident response efforts

Example Investigation

Alert

Multiple Kerberos ticket requests detected.

Findings

- Service account targeted
- Suspicious LDAP enumeration observed
- Unauthorized administrative access attempted

Analysis

Possible Kerberoasting attack combined with privilege escalation activities.

Recommended Actions

- Reset affected service account passwords
- Review privileged access
- Investigate source systems
- Enhance monitoring rules

Assignment Answers

1. Explain Kerberoasting

Kerberoasting is an attack where an attacker requests Kerberos service tickets for service accounts and cracks them offline to recover passwords. Successful attacks can lead to privilege escalation and lateral movement.

2. Describe Golden Ticket Attacks

Golden Ticket attacks involve forging Kerberos Ticket Granting Tickets using the KRBTGT account hash, enabling attackers to impersonate any user and gain extensive domain access.

3. Explain DCSync Attacks

DCSync attacks allow attackers to impersonate a Domain Controller and request password hashes through AD replication protocols, potentially compromising all domain accounts.

4. Analyze LDAP Abuse Indicators

Key LDAP abuse indicators include:

- Excessive LDAP queries
- Enumeration of users and groups
- Discovery of privileged accounts
- Large authentication-related requests
- Reconnaissance behavior

5. Research Privilege Escalation Methods

Common privilege escalation methods include:

- Token impersonation
- Credential theft
- Pass-the-Hash
- Kerberoasting
- Misconfigured permissions
- Exploiting vulnerable services
- Golden Ticket attacks